

to make in its security and for its application developers to create more secure apps.

The penetration testing process can be divided into the following five stages:

- Planning and reconnaissance
- Scanning
- Gaining access
- Maintaining access
- Analysis and WAF (Web application firewall) configuration

Planning and reconnaissance: This is the first stage of penetration testing, which involves the following activities:

- Defining the scope and goals of a test, including the system to be addressed and testing methods to be used.
- Gathering all information with regard to the network, domain names and mail servers to understand how the target works and detect vulnerabilities.

Scanning: This is the second stage of penetration testing to understand how the target application will respond to various intrusion attempts, and includes the following:

- Static analysis, which is a detailed inspection of application code to understand its behaviour. For this analysis, there are tools available to scan the entire code in a single way.
- Dynamic analysis is the detailed inspection of running application code, which is done to understand the real-time performance of the app.

Gaining access: During this stage, various attacks are performed, like SQL injection, backdoors and XSS, in order to uncover various vulnerabilities. In this stage, testers attempt to intercept the traffic, steal data and then analyse the results to assess the damage, if any.

Maintaining access: In this stage, various advanced persistent threats are performed by the pen testers to achieve a persistent presence in the system, and to uncover any hidden channels that could be used to steal an organisation's sensitive data.

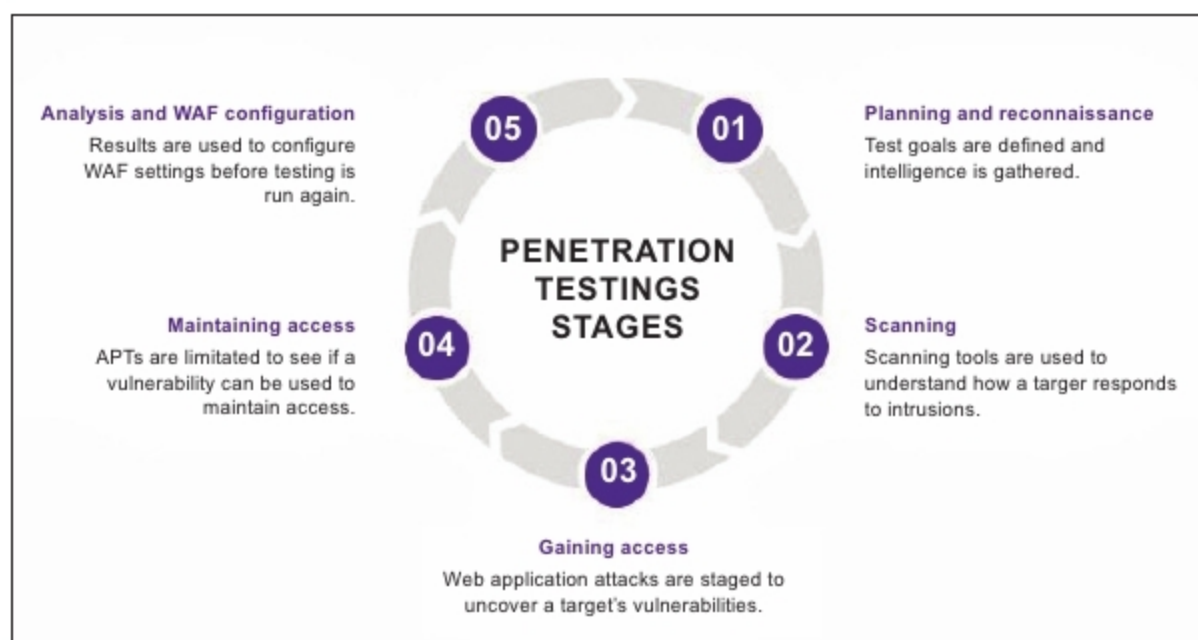


Figure 2: The five stages of penetration testing

Analysis: This stage is the final outcome of the penetration test, highlighting the vulnerabilities and backdoors in the system as well as the hidden sensitive points, which could be catastrophic.

Types of penetration testing

- **White box pen test:** In this case, the hacker will be provided with some information ahead of time, regarding the target company's security information.
- **Black box pen test:** Also known as a 'blind' test, this is a test for which the hacker is given no background information besides the name of the target company.
- **Covert pen test:** Also known as a 'double-blind' pen test, in this situation, almost no one in the company is aware that the pen test is happening, including the IT and security professionals who will be responding to the attack. For covert tests, it is especially important for the hacker to have the scope and other details of the test in writing, beforehand, to avoid any problems with law enforcement agencies, later on.
- **External pen test:** In this case, the ethical hacker goes up against the company's external-facing technology, such as its website and external network servers. In some

cases, the hacker may not even be allowed to enter the company's building. This can mean conducting the attack from a remote location or carrying out the test from a truck or van parked nearby.

- **Internal pen test:** In this case, the ethical hacker performs the test from the company's internal network. This kind of test is useful in determining how much damage a disgruntled employee can cause from behind the company's firewall.

Penetration testing methodologies and standards

The following five are regarded as the top penetration testing methodologies and standards today.

OSSTMM (Open Source Security Testing Methodology Manual)

This is a peer-reviewed methodology for security testing, maintained by the Institute for Security and Open Methodologies (ISECOM). The manual is updated every six months or so, to remain relevant to the current state of security testing. ISECOM says its main objective with the OSSTMM is to provide a scientific process for the accurate characterisation of operation security that can be used for penetration testing, ethical hacking, and other security testing. ISECOM